APOSTILA 2 — SOC E BLUE TEAM

Fundamentos de monitoramento, detecção, triagem e resposta a incidentes

Objetivo: transformar os fundamentos de Cybersecurity em raciocínio de analista SOC. A proposta é entender o que chega como alerta, como investigar, como diferenciar sinal de ruído e como documentar uma decisão.

Regra desta apostila: você não precisa decorar nomes de ferramentas. Primeiro entenda o fluxo: evento → alerta → triagem → investigação → decisão → resposta → documentação.

Foco: Blue Team / SOC • nível inicial

Módulo 1 — O que é um SOC?

SOC significa Security Operations Center, ou Centro de Operações de Segurança. É a estrutura responsável por monitorar ambientes, identificar comportamentos suspeitos e apoiar a resposta a incidentes.

Pense no SOC como uma central de vigilância digital. Ela recebe sinais de computadores, servidores, contas, aplicações, redes e ferramentas de segurança. O analista precisa transformar esses sinais em uma decisão.

O trabalho do analista

• Monitorar: acompanhar eventos e alertas.

• Triar: decidir quais alertas merecem atenção primeiro.

• Investigar: buscar contexto e evidências.

• Classificar: determinar se é benigno, suspeito ou incidente.

• Responder/encaminhar: aplicar o procedimento adequado ou escalar para outra equipe.

• Documentar: registrar o que aconteceu, o que foi analisado e qual foi a decisão.

L1, L2 e L3

Nível	Foco típico
L1	Monitoramento, triagem inicial, validação básica, enriquecimento e escalonamento.
L2	Investigação mais profunda, correlação de eventos, análise de evidências e resposta mais técnica.
L3	Casos complexos, engenharia de detecção, threat hunting, malware/reverse engineering e problemas avançados.

> Importante: os nomes e responsabilidades variam entre empresas. Uma vaga de “SOC L1” pode exigir mais ou menos atividades dependendo do ambiente.

Módulo 2 — Evento, alerta e incidente

Esses três termos parecem semelhantes, mas não são a mesma coisa.

Termo	O que significa	Exemplo
Evento	Algo que aconteceu e foi registrado.	Um login ocorreu às 03:15.
Alerta	Um evento ou conjunto de eventos que uma regra considerou relevante.	5 tentativas de login falharam em 1 minuto.
Incidente	Uma situação que realmente representa comprometimento, violação ou risco para a empresa.	Um colaborador teve sua conta usada para acessar dados indevidamente.

> Regra mental: nem todo evento é alerta; nem todo alerta é incidente.

Um SOC eficiente não tenta tratar tudo como ataque. Ele precisa reduzir o ruído e encontrar aquilo que realmente merece investigação.

Módulo 3 — SIEM

SIEM significa Security Information and Event Management. É uma plataforma usada para centralizar, pesquisar, correlacionar e analisar registros de diferentes fontes.

Por que centralizar logs?

Imagine investigar uma invasão consultando manualmente dezenas de computadores, servidores e sistemas. O SIEM reduz esse trabalho ao reunir os registros em um local onde podem ser pesquisados e correlacionados.

Fontes comuns

• Windows Event Logs

• Linux logs

• Firewalls e dispositivos de rede

• VPN

• Servidores web

• Aplicações

• Serviços de identidade

• EDR/XDR

• Sistemas de autenticação

Correlação

Correlação significa relacionar eventos que, isoladamente, podem parecer normais, mas juntos formam um padrão suspeito.

Exemplo: login bem-sucedido → criação de processo suspeito → conexão com IP externo → tentativa de acesso a arquivos sensíveis. O conjunto pode ser muito mais importante do que qualquer evento isolado.

Módulo 4 — Logs: lendo o que aconteceu

Um log é um registro de uma atividade. Para o analista, ele funciona como uma peça de evidência.

Campos que você deve procurar

Campo	Pergunta que ajuda a responder
Timestamp	Quando aconteceu?
Usuário	Quem estava envolvido?
Host/IP	Em qual máquina ou endereço ocorreu?
Ação	O que foi feito?
Resultado	Foi permitido, bloqueado ou falhou?
Processo	Qual programa executou a ação?
Origem/destino	De onde veio e para onde foi a comunicação?
ID do evento	Que tipo de evento foi registrado?

> Dica: antes de perguntar “isso é ataque?”, pergunte “o que exatamente aconteceu?”. Depois procure contexto.

Módulo 5 — EDR

EDR significa Endpoint Detection and Response. É uma tecnologia voltada para monitorar endpoints — como computadores e servidores — coletando telemetria e ajudando a detectar e responder a comportamentos suspeitos.

O que um EDR pode mostrar?

- Processos criados
- Linha de comando
- Arquivos criados/modificados
- Conexões de rede
- Usuário associado à atividade
- Persistência e alterações relevantes
- Comportamentos classificados como suspeitos

> SIEM × EDR: o SIEM é muito forte na visão centralizada e correlação de eventos de várias fontes. O EDR é especializado no endpoint e costuma fornecer uma visão mais detalhada do comportamento naquele dispositivo.

Módulo 6 — IOC, IOA e comportamento

IOC — Indicator of Compromise

É uma evidência ou indicador associado a um possível comprometimento. Exemplos: hash de arquivo malicioso, domínio suspeito, IP associado a atividade maliciosa ou artefato específico.

IOA — Indicator of Attack

É um indicador de comportamento associado a uma tentativa ou execução de ataque. Em vez de depender apenas de uma assinatura, observa como algo está acontecendo.

IOC	IOA
Foca em evidência/artefato.	Foca em comportamento/padrão.
Ex.: hash conhecido de malware.	Ex.: processo incomum executando uma sequência suspeita.
Pode ser muito específico.	Pode ajudar a detectar variações de uma técnica.

Para o Blue Team: não dependa de um único indicador. Um atacante pode trocar um arquivo, domínio ou IP; o comportamento pode continuar semelhante.

Módulo 7 — Triage: como priorizar um alerta

Triagem é a avaliação inicial para entender o que o alerta representa e o que deve ser feito a seguir.

Perguntas básicas

- O que aconteceu?
- Quando aconteceu?
- Em qual usuário/host?
- Qual foi a origem e o destino?
- É uma atividade esperada?
- Há outros eventos relacionados?
- Existe evidência de comprometimento?
- Qual é o impacto potencial?
- Precisa ser escalado ou contido?

Severidade não é a mesma coisa que certeza

Um alerta pode ter alta severidade porque o possível impacto é grande, mesmo antes de você ter certeza de que houve comprometimento. A investigação serve justamente para aumentar a confiança na conclusão.

Pergunta	Exemplo
Probabilidade	Há evidências fortes de que a atividade é maliciosa?
Impacto	Se for maliciosa, o que pode ser afetado?
Urgência	Precisamos agir agora para reduzir o risco?

Módulo 8 — Falso positivo

Um falso positivo ocorre quando uma regra gera um alerta, mas a atividade analisada é legítima.

Exemplo: uma ferramenta detecta muitas tentativas de login porque um sistema corporativo está configurado para testar autenticação automaticamente. O padrão parece suspeito, mas há uma explicação legítima.

O que fazer?

• Não simplesmente fechar o alerta.

• Validar contexto.

• Identificar a causa legítima.

• Documentar a justificativa.

• Se apropriado, sugerir ajuste da regra para reduzir ruído.

O objetivo não é zerar alertas. É melhorar a qualidade dos alertas para que o time consiga encontrar ameaças reais.

Módulo 9 — Investigação e timeline

Uma timeline organiza os acontecimentos em ordem cronológica. Ela ajuda a responder: o que aconteceu primeiro, o que veio depois e como os eventos se relacionam.

Exemplo de investigação

Hora	Evento
09:12	Login de usuário em workstation.
09:14	Processo incomum iniciado.
09:15	Conexão de saída para domínio desconhecido.
09:17	Arquivo novo criado em diretório temporário.
09:20	EDR gera alerta.

Observe que o alerta apareceu às 09:20, mas a atividade relevante começou antes. Um bom analista olha para trás e procura a origem do comportamento.

Módulo 10 — Ciclo de resposta a incidentes

Quando um evento é confirmado como incidente, a organização precisa seguir um processo estruturado.

Etapa	Objetivo
Preparação	Ter pessoas, ferramentas, acessos e procedimentos prontos.
Identificação	Detectar e confirmar o incidente.
Contenção	Reduzir a capacidade de o incidente continuar causando dano.
Erradicação	Remover a causa ou artefatos maliciosos.
Recuperação	Restaurar a operação com segurança.
Lições aprendidas	Entender o que melhorar para evitar repetição.

Importante: no SOC, você nem sempre executará todas essas etapas. Muitas vezes sua responsabilidade é detectar, investigar, documentar e escalar corretamente.

Módulo 11 — MITRE ATT&CK;

MITRE ATT&CK; é uma base de conhecimento usada para organizar técnicas e comportamentos associados a ataques. Para um iniciante em SOC, o mais importante é entender a lógica.

Em vez de pensar apenas “qual malware é esse?”, o analista pode perguntar: “qual comportamento está acontecendo e qual técnica isso pode representar?”

Por que isso ajuda?

• Padroniza a descrição de comportamentos.

• Ajuda a criar e melhorar detecções.

• Ajuda na investigação.

• Facilita a comunicação entre profissionais.

• Permite identificar lacunas de monitoramento.

Você não precisa decorar a matriz. Aprenda primeiro a reconhecer comportamentos e depois consulte a referência quando necessário.

Módulo 12 — Playbooks

Playbook é um procedimento documentado para tratar determinado tipo de alerta ou incidente.

Exemplo: um playbook para “login suspeito” pode orientar quais dados verificar, quais perguntas responder, quando bloquear uma conta, quando escalar e como registrar a investigação.

Por que usar playbooks?

• Reduz improvisação.

• Padroniza decisões.

• Acelera o atendimento.

• Ajuda profissionais novos.

• Facilita auditoria e melhoria do processo.

Módulo 13 — Como pensar como analista SOC

O principal aprendizado desta apostila não é decorar ferramentas. É desenvolver uma sequência de raciocínio.

Passo	Pergunta
1. Observar	O que o alerta está dizendo?
2. Validar	O evento realmente ocorreu?
3. Contextualizar	Quem, onde, quando, o quê e por quê?
4. Correlacionar	Existem outros eventos relacionados?
5. Avaliar	É legítimo, suspeito ou incidente?
6. Agir	Encerrar, monitorar, escalar ou responder?
7. Documentar	Como justificar a decisão?

Frase para guardar: “Não investigue apenas o alerta; investigue a história que levou ao alerta.”

Módulo 14 — Cenários de treinamento

Cenário 1 — Muitas tentativas de login

Um usuário apresenta 30 falhas de autenticação em poucos minutos e depois ocorre um login bem-sucedido.

Raciocínio: investigar origem, horário, dispositivo, localização/contexto, se o usuário reconhece a atividade e quais eventos ocorreram imediatamente depois.

Não conclua automaticamente: “é ataque”. Pode ser senha errada, sistema automatizado, usuário com problema ou tentativa de comprometimento.

Cenário 2 — PowerShell suspeito

O EDR registra PowerShell executando um comando incomum em uma máquina corporativa.

Raciocínio: descobrir qual usuário executou, processo pai, linha de comando, horário, finalidade, conexões posteriores e se existe contexto administrativo legítimo.

PowerShell não é sinônimo de malware. É uma ferramenta legítima que também pode ser abusada.

Cenário 3 — Domínio desconhecido

Um endpoint faz conexão para um domínio que ninguém reconhece.

Raciocínio: descobrir qual processo realizou a conexão, qual usuário estava ativo, frequência, destino/IP, reputação/contexto disponível e o que aconteceu antes/depois.

“Desconhecido” não significa automaticamente “malicioso”.

Módulo 15 — Exercícios de fixação

Instrução: tente responder sem consultar a apostila. A alternativa D significa “não sei”. O objetivo é identificar o que você realmente entendeu.

1. Qual afirmação melhor diferencia evento, alerta e incidente?

A) Evento é sempre um ataque; alerta é sempre um incidente; incidente é sempre malware.

B) Evento é um registro; alerta é uma sinalização relevante; incidente é uma situação que exige tratamento de segurança.

C) Evento e alerta são sinônimos; incidente é apenas um log importante.

D) Não sei.

2. Qual é uma função típica de um SIEM?

A) Substituir todos os antivírus do ambiente.
B) Centralizar e correlacionar registros de várias fontes.
C) Criar senhas automaticamente para usuários.
D) Não sei.

3. O que caracteriza melhor um EDR?

A) Monitoramento e resposta focados em endpoints.
B) Sistema usado somente para armazenar backups.
C) Serviço usado exclusivamente para traduzir nomes DNS.
D) Não sei.

4. O que é um IOC?

A) Um indicador ou artefato associado a possível comprometimento.
B) Um procedimento obrigatório de contratação.
C) Um tipo de firewall físico.
D) Não sei.

5. Qual é uma boa primeira pergunta ao receber um alerta?

A) Qual ferramenta devo instalar?
B) O que exatamente aconteceu e em qual contexto?
C) Como derrubar imediatamente a máquina?
D) Não sei.

6. Um falso positivo deve ser simplesmente ignorado?

A) Sim, sempre.
B) Não; deve ser validado, justificado e, quando apropriado, usado para melhorar a detecção.
C) Sim, porque todo alerta falso é inútil.
D) Não sei.

7. Por que uma timeline ajuda em uma investigação?

A) Porque organiza eventos e ajuda a entender a sequência dos acontecimentos.
B) Porque substitui todos os logs.
C) Porque garante que o alerta é verdadeiro.
D) Não sei.

8. O que significa contenção em resposta a incidentes?

A) Reduzir a capacidade de o incidente continuar causando dano.
B) Apagar todos os logs.
C) Publicar o incidente nas redes sociais.
D) Não sei.

9. Por que MITRE ATT&CK; é útil para um SOC?

A) Porque ajuda a organizar e comunicar comportamentos e técnicas de ataque.
B) Porque é um antivírus gratuito.
C) Porque substitui o SIEM.
D) Não sei.

10. Qual raciocínio é mais adequado para um analista SOC?

A) Ver alerta e imediatamente concluir que é ataque.

B) Observar, validar, contextualizar, correlacionar, avaliar, agir e documentar.

C) Fechar todos os alertas de baixa severidade sem investigar.

D) Não sei.

Gabarito — use somente depois de responder

1-B

2-B

3-A

4-A

5-B

6-B

7-A

8-A

9-A

10-B

Interpretação sugerida: 9–10 = ótimo domínio inicial; 7–8 = bom, mas revise os erros; 5–6 = revise os módulos antes de avançar; 0–4 = volte aos fundamentos e refaça os exercícios.

Importante: acertar por memória não é o objetivo. Se você não consegue explicar por que a alternativa está correta, marque o assunto para revisão.

Glossário rápido

Termo	Significado
SOC	Security Operations Center — estrutura de operações de segurança.
SIEM	Plataforma de centralização, pesquisa e correlação de eventos.
EDR	Endpoint Detection and Response — monitoramento e resposta em endpoints.
Log	Registro de uma atividade ou evento.
IOC	Indicator of Compromise — indicador associado a possível comprometimento.
IOA	Indicator of Attack — indicador baseado em comportamento de ataque.
Triage	Triagem e priorização de alertas.
Playbook	Procedimento documentado para tratar um cenário.
Timeline	Linha do tempo dos acontecimentos.
MITRE ATT&CK	Base de conhecimento sobre técnicas e comportamentos de ataque.